



# Secure Software Engineering

**BITS Pilani**



**BITS Pilani**  
Pilani Campus



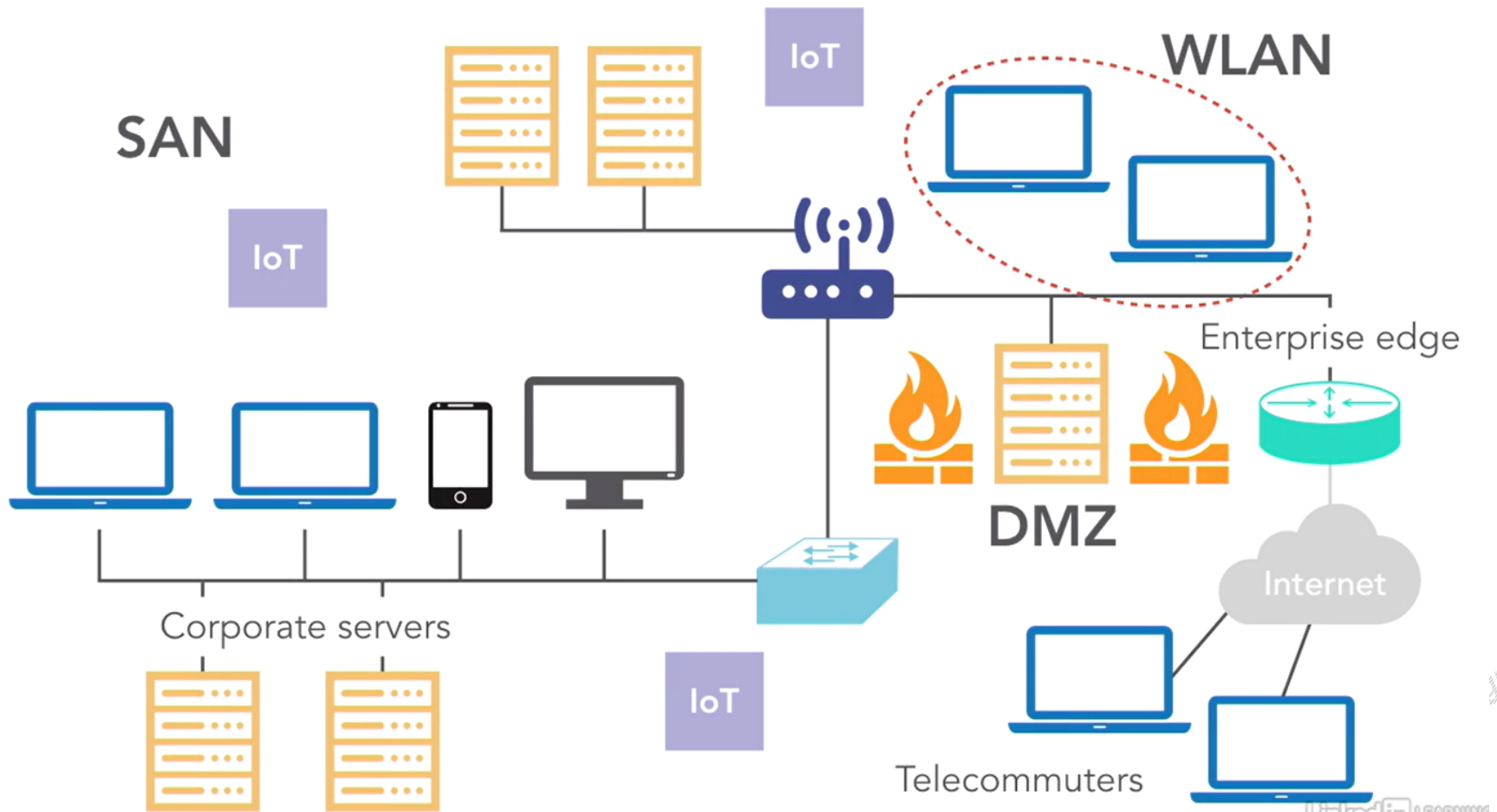
# Defence in Depth

# Defense : Keep Endpoint Safe



**Defense-in-depth strategies require the use of diverse, overlapping security controls.**

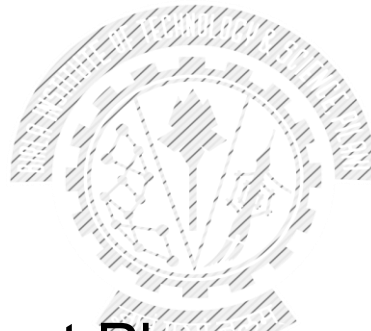
# Keep Endpoint Safe



# What are the End Points in the Diagram?



- ☐ Workstations
- ☐ Storage Area Device
- ☐ Networking Device
- ☐ Servers
- ☐ IoT Devices
- ☐ Telecommuters / Internet Phones
- ☐ Remote and Mobile Workers



# Attack Vectors



An attack vector is a path or means by which an attacker or hacker can gain access to a computer or network server in order to deliver a payload or malicious outcome. Attack vectors enable hackers to exploit system vulnerabilities, including the human element

- A way for a malicious actor to gain access into a system

Includes software, networks, and the user

- Attack vectors on the endpoints can vary

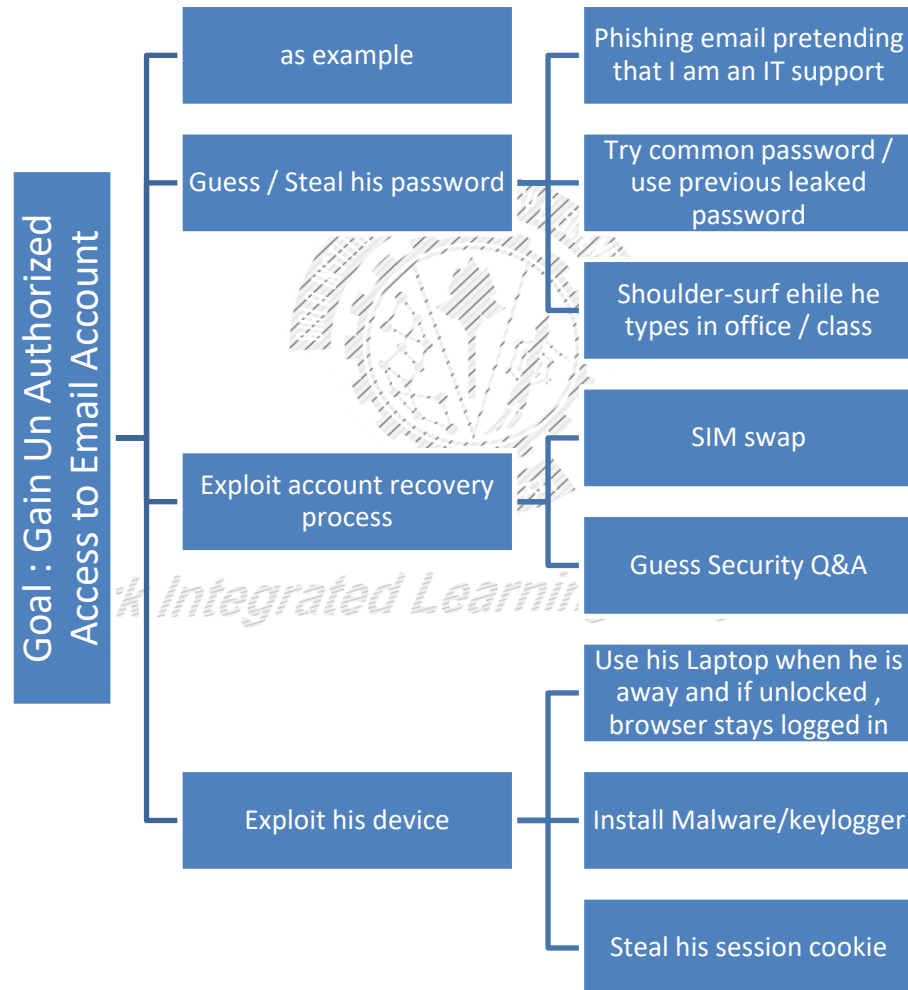
Will depend on the individual organization

# GOAL : Attack Tree

innovate

achieve

lead





# Endpoint Attack Vectors



- **Software** represents the largest attack surface and includes applications, services, executables, and webpages
- The **network** attack surface includes devices and interfaces, ports on outward-facing servers
- The **human** attack surface can introduce malicious behavior into the network either accidentally or maliciously



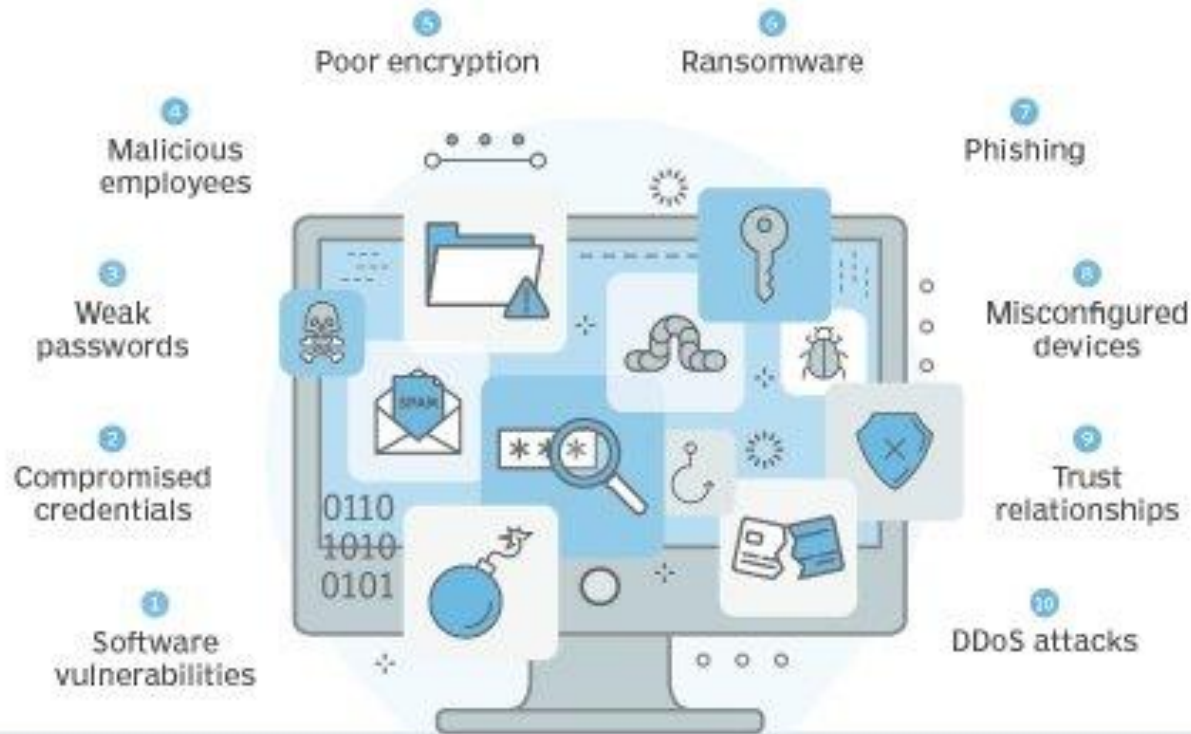
# Attack Vectors

innovate

achieve

lead

## 10 common attack vectors



# Defense in Depth

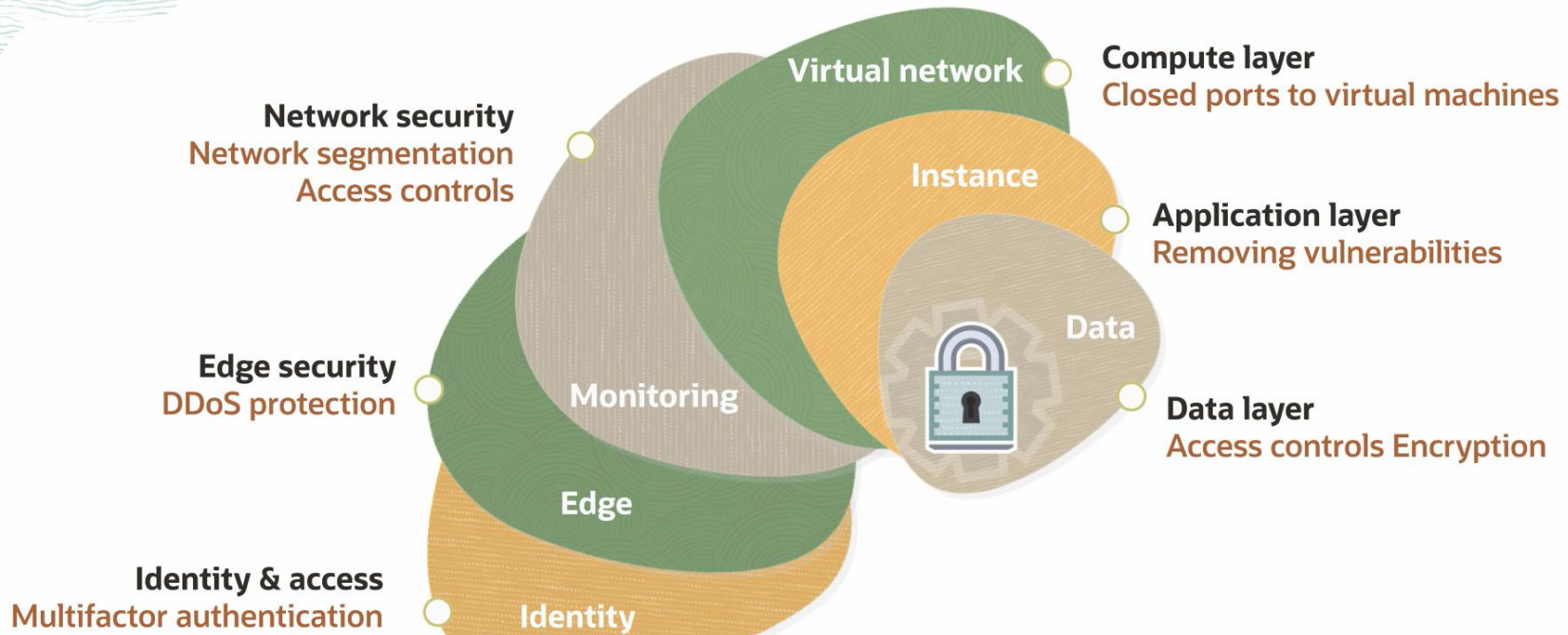
innovate

achieve

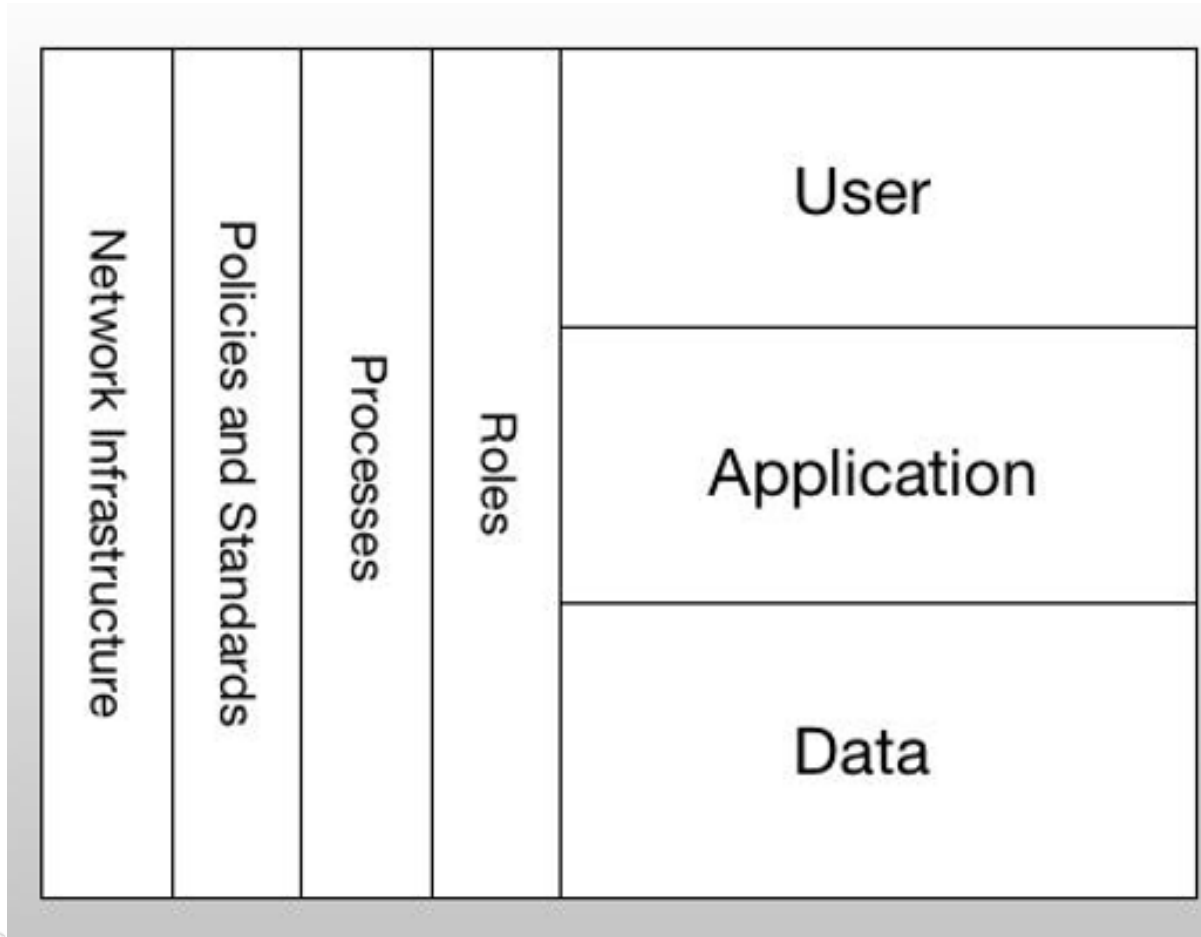
lead

## Defense in Depth

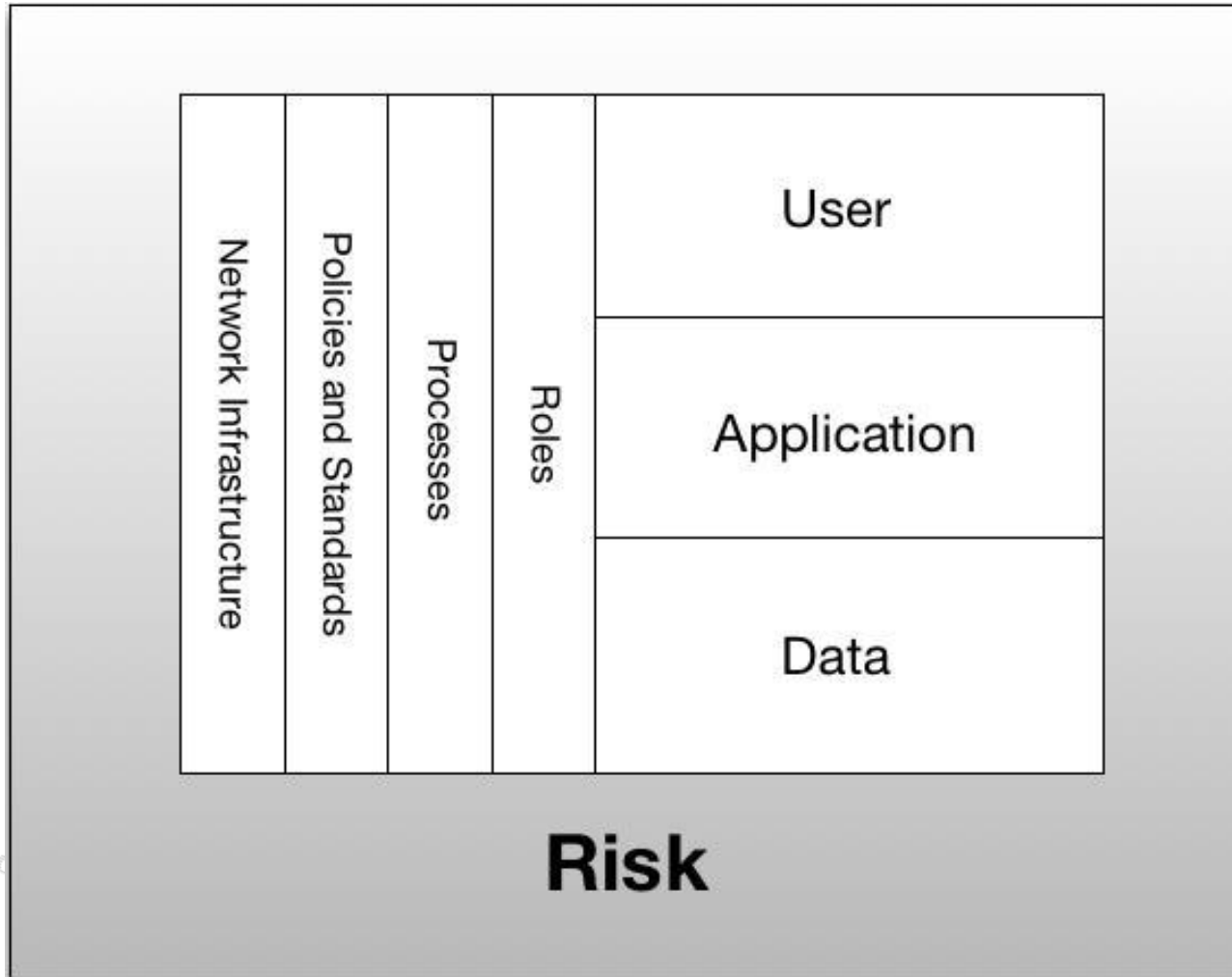
### Security Controls



# Comprehensive Security Architecture



# Comprehensive Security Architecture



# Minimize the RISK

innovate

achieve

lead

Broad set of tactics and solutions to minimize the risk and impact of a cybersecurity *incident*



# Security Terminologies



## Risk

- An expectation of loss expressed as the probability that a particular threat will exploit a particular vulnerability with a particular harmful result.

## Threat

- A potential for violation of security, which exists when there is a circumstance, capability, action, or event, that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

## Vulnerability

- A flaw or weakness in a system's design, implementation, or operation and management that could be exploited to violate the system's security policy.



# Zero Trust

innovate

achieve

lead

**Zero Trust Security** is a modern cybersecurity model based on the principle of **"never trust, always verify."** Unlike traditional security models that assume everything inside an organization's network can be trusted, Zero Trust assumes that **no user, device, or application—inside or outside the network—should be trusted by default.**

## Zero Trust principles

### Verify explicitly

Always authenticate and authorize based on all available data points, including user identity, location, device health, service or workload, data classification, and anomalies.

### Use least privileged access

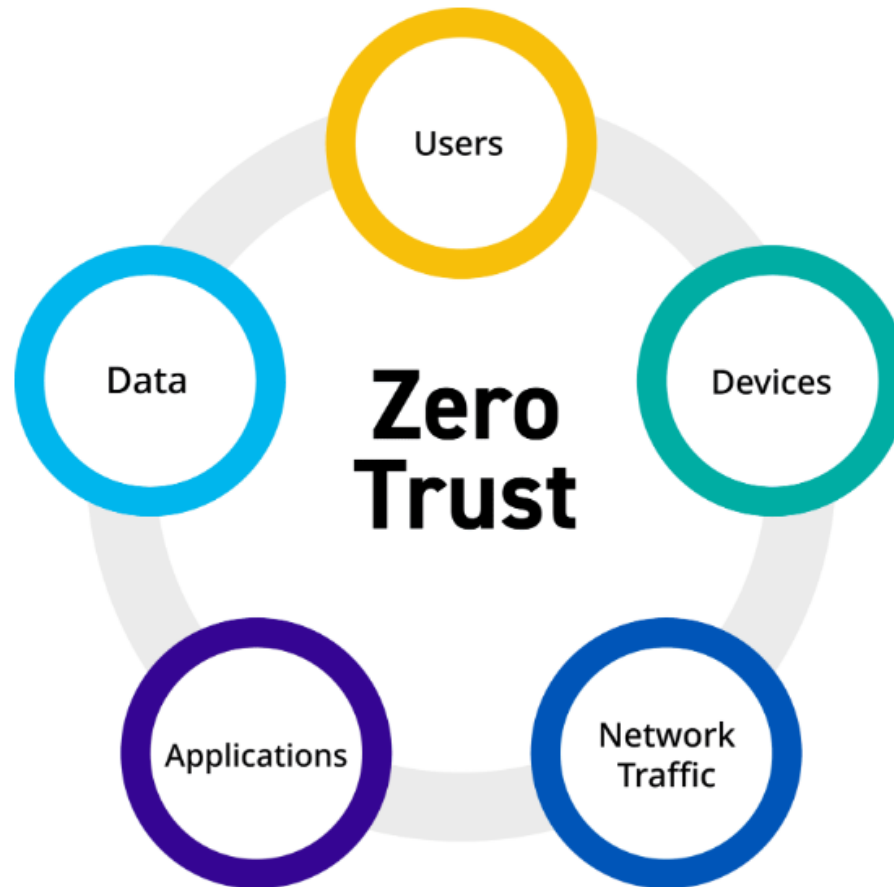
Limit user access with just-in-time and just-enough-access (JIT/JEA), risk-based adaptive policies, and data protection to help secure both data and productivity.

### Assume breach

Minimize blast radius and segment access. Verify end-to-end encryption and use analytics to get visibility, drive threat detection, and improve defenses.



# Zero Trust



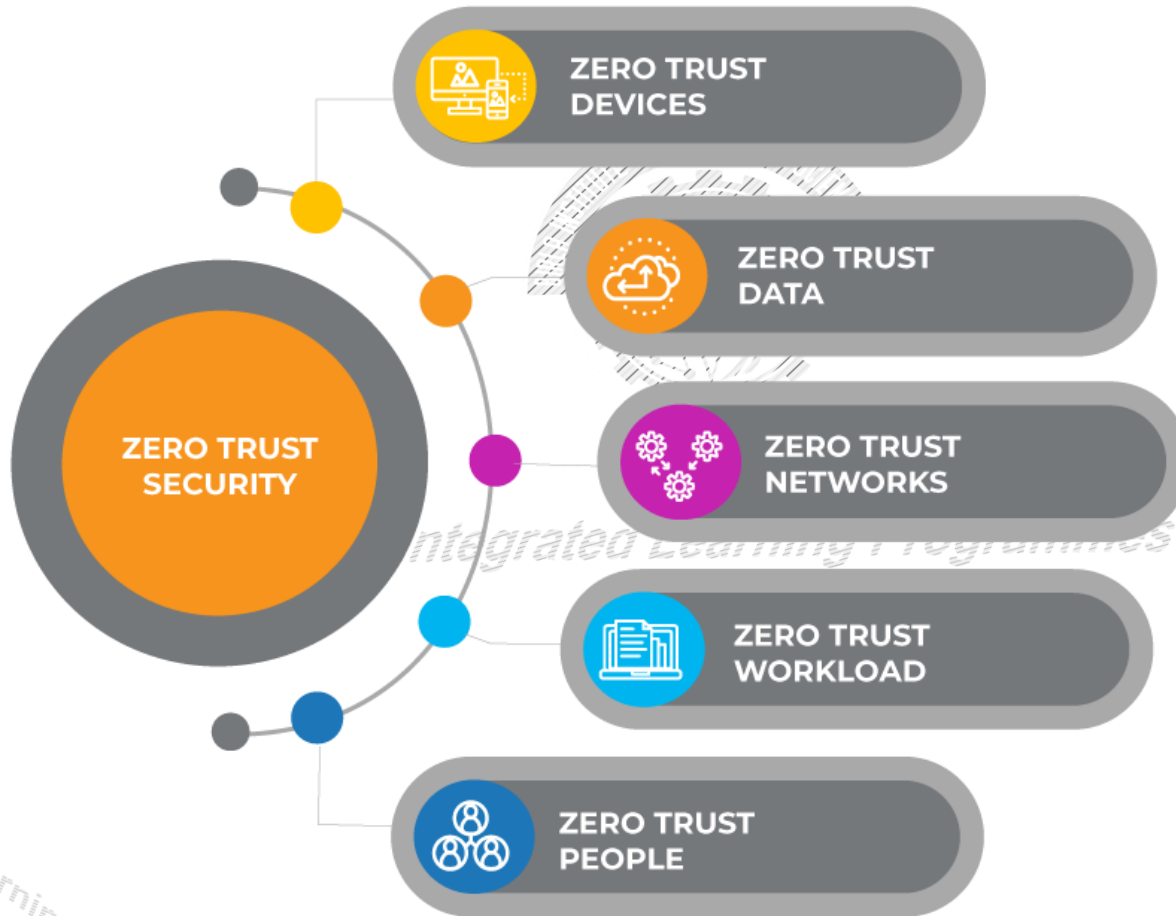
<https://www.microsoft.com/en-in/security/business/zero-trust>

# Zero Trust

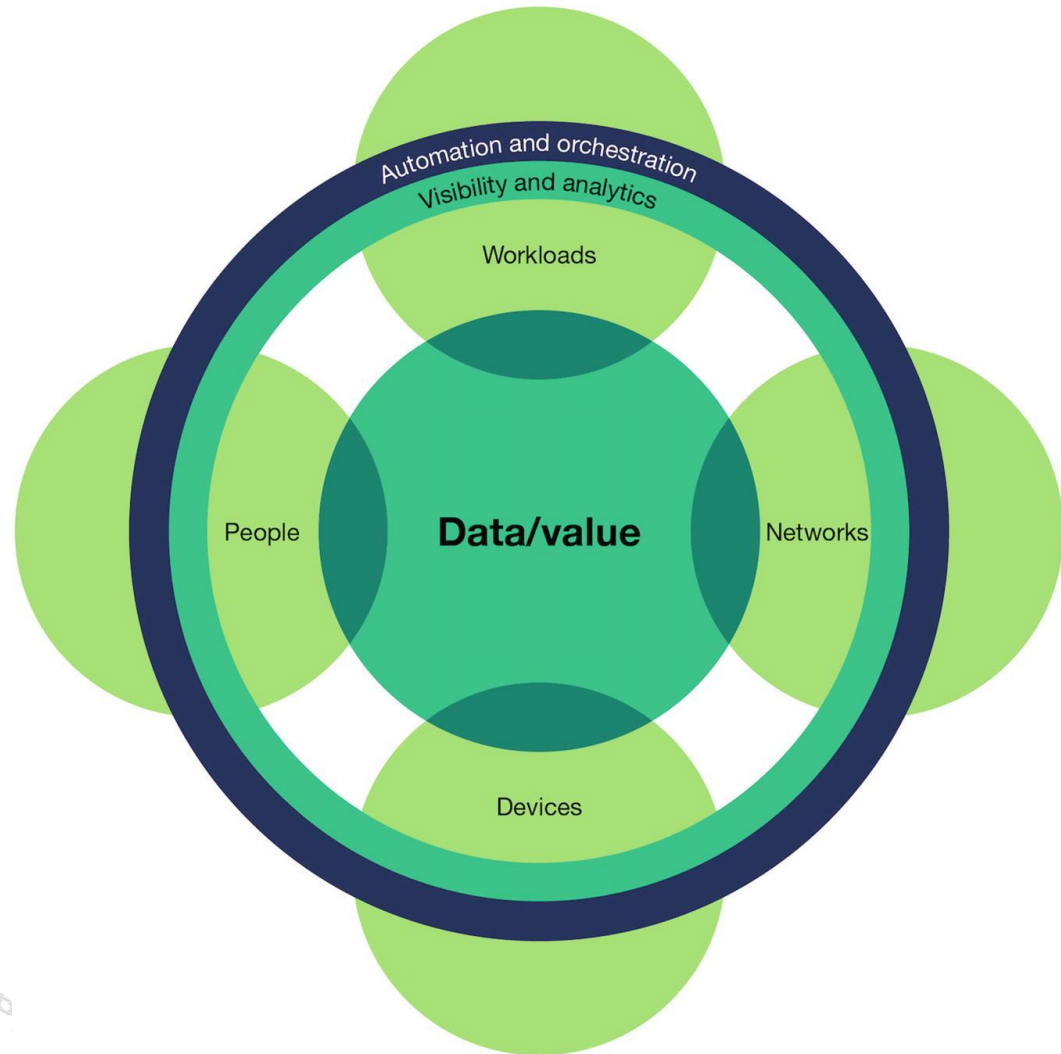
innovate

achieve

lead



# Forrester Zero Trust eXtended Model



# Zero Trust



**Data :** Data is the center of the ZTX model, and it includes Data Classification and Protection at the core of the requirements to support the Zero Trust Model. Additionally, Data Loss Prevention (DLP) should be a part of a Zero Trust architecture, and tied into the policy model with the ability to enforce contextual access policies where possible.

**Networks:** The Network pillar of the ZTX model is primarily focused on network segmentation—both from a user and a server perspective—to provide better security based on identity-centric attributes. It's important to recognize that enterprises have many existing components that make up the traditional network security infrastructure, such as Next-Generation Firewalls (NGFWs), Web Application Firewalls (WAF), Network Access Control (NAC) solutions, and Intrusion Protection Systems (IPS). These components generally all have a role to play in a Zero Trust system.

# Zero Trust



**People** : The People pillar of the ZTX model must include multiple elements of Identity and Access Management (IAM). Role- and Attribute-Based Access Control (RBAC and ABAC) are well-understood models within IAM, and Zero Trust enables the use of these more broadly, and more effectively, across the enterprise infrastructure. Multi-Factor Authentication (MFA) is another requirement and is essential to supporting Zero Trust. Finally, Single Sign On (SSO)—using modern, open standards such as OAuth and SAML—is another core element within the people pillar.

**Workloads**: Workloads, as defined by Forrester, consist of the components that make up the logical functions that drive business within both customer facing and backend business systems—containers, applications, infrastructure, processes, etc. Zero Trust requires metadata-driven workload access controls, enforced consistently across hybrid environments.

# Implementation Policy summary



1. **Map the attack surface:** Identify users, devices, applications, and data.
2. **Define protection surfaces:** What data/applications are most critical?
3. **Architect the Zero Trust network:** Use software-defined perimeters and micro-segmentation.
4. **Create policy:** Determine who can access what, under what conditions.
5. **Monitor and maintain:** Use logging, analytics, and threat detection continuously.

*Work Integrated Learning Programmes*

# Example Use Case



## Remote Work Security

Zero Trust ensures that a remote employee using a personal laptop must:

- Pass identity verification via MFA
- Use a secure, verified device
- Access only permitted apps/data
- Be monitored for unusual behavior



# Threat Modelling

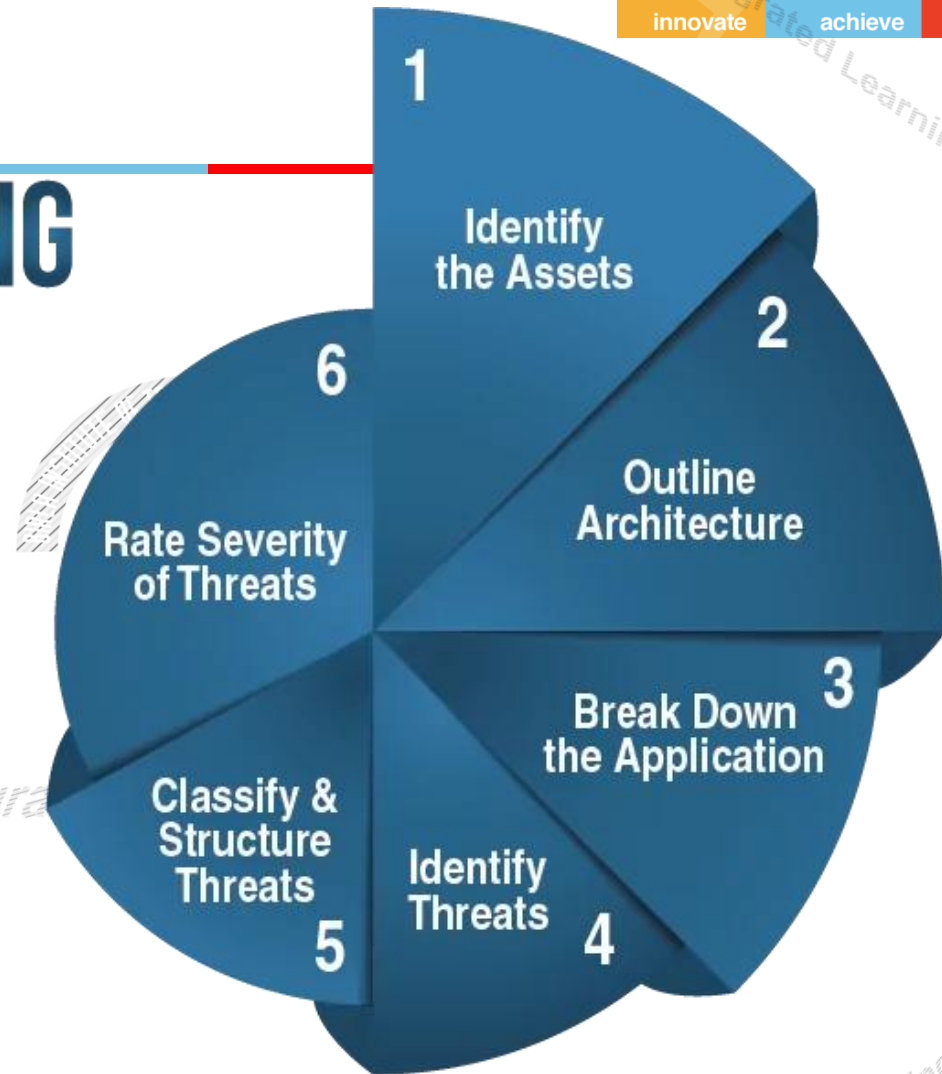


- ❑ Identifying, analyzing, and rating security threats
- ❑ Producing prioritized mitigations
- ❑ Assisting and informing attack surface analysis and risk reduction



*Work Integrated Learning Programmes*

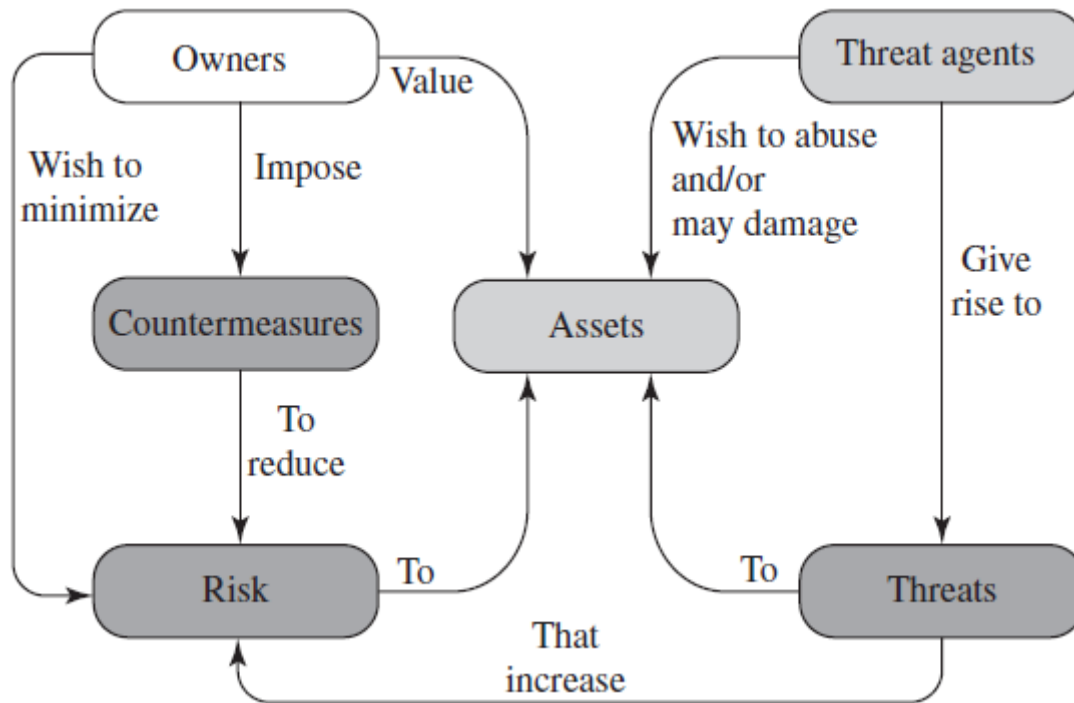
# STEPS TO THREAT MODELING



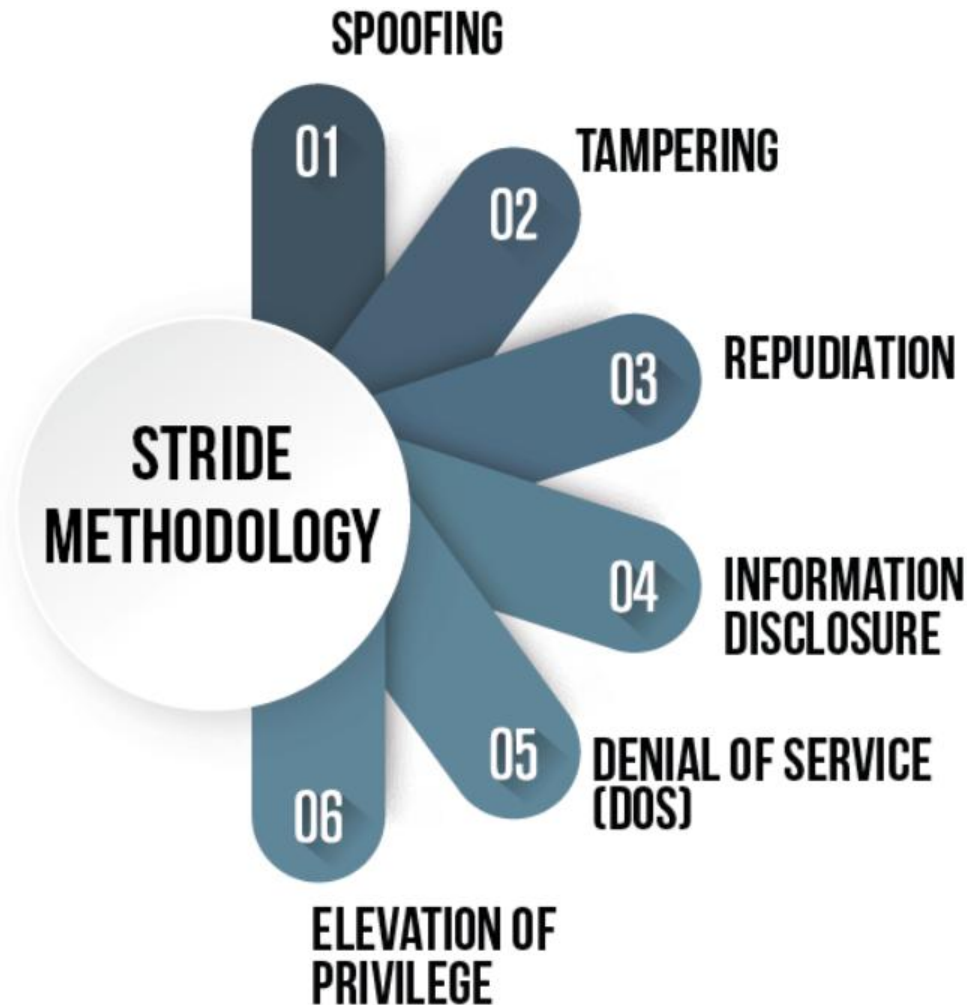
# Threat Modelling Process



- **Step 1:** Scope your work.
- **Step 2:** Identify Threats.
- **Step 3:** Determine Countermeasures and Mitigation.
- **Step 4:** Assess your work.



# STRIDE



# What is repudiation?



Repudiation, in its simplest form, is the act of denying something that one has done.

In cybersecurity, this can involve denying the authenticity of a message, the initiation of a transaction, or the making of changes to a system.

## Examples of repudiation attacks:

1. A user could send a message that they later deny sending, possibly to avoid responsibility for a damaging statement.
2. An attacker could perform a financial transaction and then claim they did not do it, allowing them to avoid financial repercussions.
3. An attacker could modify system logs to conceal their activities, making it difficult to trace their actions.

# STRIDE



|   | Type of Threat          | What Was Violated | How Was It Violated?                                                   |
|---|-------------------------|-------------------|------------------------------------------------------------------------|
| S | Spoofing                | Authentication    | Impersonating something or someone known and trusted.                  |
| T | Tampering               | Integrity         | Modifying data on disk, memory, network, etc.,                         |
| R | Repudiation             | Non-repudiation   | Claim to not be responsible for an action                              |
| I | Information Disclosure  | Confidentiality   | Providing information to someone who is not authorized                 |
| D | Denial of Service (DoS) | Availability      | Denying or obstructing access to resources required to provide service |
| E | Elevation of Privilege  | Authorization     | Allowing access to someone without proper authorization                |

# Core Threat Modeling Activities



1. Define threat modeling goals (confidentiality, integrity, etc.).
2. Set scope: what systems/cloud are we assessing?
3. Break down systems and analyze interactions.
4. Identify & rate potential threats (unauthorized access, DoS, etc.).
5. Find weaknesses in system design for security testing.
6. Design & prioritize controls to mitigate threats.
7. Communicate findings & propose controls for threat mitigation.



# STRIDE

## 1. Spoofing



**Scenario:** An attacker pretends to be a legitimate user by stealing their login credentials (username and password) via phishing and logs into the banking portal to initiate a fund transfer.

- **Threat:** Unauthorized access to user accounts.
- **Mitigation:** Use multifactor authentication (MFA), biometrics, or device fingerprinting.

*Work Integrated Learning Programmes*

# STRIDE

## 2. Tampering



**Scenario:** A hacker intercepts and alters a fund transfer request sent from a mobile banking app to the server, changing the recipient account number to their own.

- ❑ **Threat:** Data or code is maliciously modified.
- ❑ **Mitigation:** Implement message signing, use HTTPS/TLS, and validate data integrity using checksums or hashes.

*Work Integrated Learning Programmes*

## 3. Repudiation



**Scenario:** A customer claims they did not make a large transfer even though they did, and there is no audit log or digital signature to prove the transaction.

- ❑ **Threat:** Users deny having performed an action.
- ❑ **Mitigation:** Keep tamper-proof audit logs, use digital signatures, and non-repudiation techniques.

*Work Integrated Learning Programmes*

## 4. Information Disclosure



**Scenario:** A web application has a misconfigured API endpoint that returns customer data (e.g., email, balance) without proper authorization checks.

- ❑ **Threat:** Exposure of sensitive data to unauthorized parties.
- ❑ **Mitigation:** Enforce access controls, encrypt sensitive data at rest and in transit, implement strict input/output validation.

*Work Integrated Learning Programmes*

## 5. Denial of Service (DoS)



**Scenario:** Attackers flood the login API of a banking application with millions of requests, causing the service to crash and become unavailable to legitimate users.

- ❑ **Threat:** Legitimate users are denied access to resources.
- ❑ **Mitigation:** Use rate limiting, Web Application Firewalls (WAF), and implement autoscaling infrastructure.

*Work Integrated Learning Programmes*

## 6. Elevation of Privilege



**Scenario:** A user discovers a bug in the mobile banking app that allows them to execute admin-level actions (like reversing transactions) without being an admin.

- ❑ **Threat:** Unauthorized user gains elevated access.
- ❑ **Mitigation:** Implement strict role-based access controls (RBAC), conduct code reviews and penetration testing.

*Work Integrated Learning Programmes*

# Question - 1



In an online banking system, what assets would be most valuable to an attacker, and how would identifying these help in prioritizing defenses against threats like *Information Disclosure*?



*Work Integrated Learning Programmes*

# Answer -1



**Customer credentials**  
(usernames, passwords)

**Personal Identifiable Information (PII)**  
(names, addresses, phone numbers)

**Financial data**  
(account balances, transaction history)

**Payment methods**  
(linked cards, UPI IDs)

**Authorization tokens / session cookies**

**Admin control panels**



# Answer-1 (second part)



Prioritize the implementation of **access controls** and **encryption** for high-value data.

Apply stricter **data flow protections** and **monitoring** around sensitive endpoints.

Focus on preventing *Information Disclosure* by encrypting data at rest/in transit, and securing APIs to avoid unauthorized access.

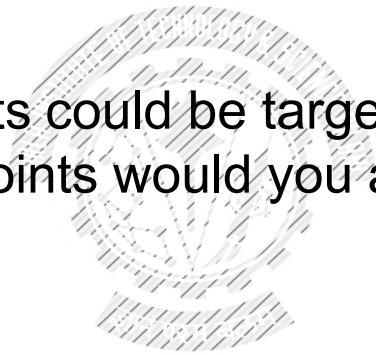
*Work Integrated Learning Programmes*

# Question - 2



While breaking down the application, you identify modules like **login**, **fund transfer**, **transaction history**, and **admin dashboard**.

Which of these components could be targeted for *Elevation of Privilege* and what entry points would you analyze?



*Work Integrated Learning Programmes*

# Answer-2



## Target Components for Elevation of Privilege:

- **Admin Dashboard:** A regular user may attempt to gain admin privileges.
- **Fund Transfer Module:** An attacker might try to bypass checks to authorize large transactions.
- **API Endpoints:** Improperly configured endpoints might allow users to invoke admin-only functions.

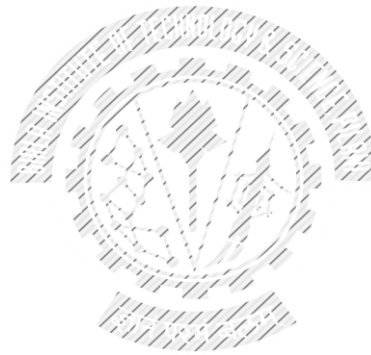
## Entry Points to Analyze:

- **Role validation logic** in APIs (e.g., `isRoleAdmin()`)
- **Frontend controls** (buttons visible/hidden in UI don't imply backend safety)
- **Access tokens** (ensure they cannot be forged or reused)
- **Logs or error messages** that may leak privilege logic

# Question - 3



Using the STRIDE model, what types of threats would you associate with the "fund transfer" functionality in the banking app?



*Work Integrated Learning Programmes*

# Answer - 4



## **Spoofing:**

- Attacker pretends to be a legitimate user using stolen credentials.

## **Tampering:**

- Intercepting and altering the transfer amount or recipient account.

## **Repudiation:**

- A user denies having performed a transfer.

## **Information Disclosure:**

- Transaction data leaked to unauthorized users.

## **Denial of Service:**

- Flooding the transfer API to disable legitimate use.

## **Elevation of Privilege:**

- Regular user invokes an API reserved for privileged roles (e.g., bulk transfers).